

Security Incident Report

Cloudora Security Operations | Template CLD-IR-TEMPLATE | Complete every section. If a section is empty, write why.

Report ID	CLD-IR-0001
Related ticket	CLD-0001 - Suspicious sign-in activity: daniel.reeve@cloudora.io
Report title	Executive account takeover via password spray, with MFA persistence and BEC staging
Analyst	SOC Analyst, Cloudora engagement (MyFirstHack training)
Date of report (UTC)	2026-08-10
Incident severity	P1 - executive mailbox compromised during an active enterprise deal; fraud staging in place
Status	Contained - eradication verified, monitoring continues
Classification	CONFIDENTIAL - Internal and client distribution only

1. Executive summary

Four to five sentences a non-technical executive can read in 60 seconds: what happened, how it was found, what the attacker did, what has been done about it, and what the business risk was.

Between 8 and 10 August 2026, an external attacker ran a low-volume password guessing campaign against 26 Cloudora staff accounts from three IP addresses in Lagos, Nigeria. In the early hours of 10 August the attacker guessed the correct passwords for two accounts: the CEO, Daniel Reeve, at 03:12 UTC and Priya Nair at 03:47 UTC. On the CEO account the attacker registered their own authentication device and created a hidden email rule that diverts finance and invoice-related mail, creating a risk of invoice fraud against Cloudora customers. The compromise was detected the same morning; both accounts were contained, the attacker device and email rule were removed, attacker network addresses were blocked, and 24 further targeted-but-not-breached accounts were flagged for precautionary password resets.

2. Incident timeline

Every significant event in order, all times in UTC. Sources: CloudoraSignIn_CL and CloudoraAudit_CL.

Aug 08, 00:00-05:00	Sign-in	Password spray night 1: 44 failed sign-ins from 102.89.x.x across ~20 accounts.	CloudoraSignIn_CL; ResultType 50126.
Aug 09, 00:00-05:00	Sign-in	Password spray night 2: 36 failed sign-ins from same source IPs.	CloudoraSignIn_CL.
Aug 10, 00:35-48	Sign-in	Spray night 3 begins; failed attempt against daniel.reeve.	CloudoraSignIn_CL; 102.89.44.17.
Aug 10, 03:09:12	Sign-in	Failed sign-in to daniel.reeve from Lagos.	CloudoraSignIn_CL; ResultType 50126.
Aug 10, 03:10:41	Sign-in	Second failed sign-in to daniel.reeve from Lagos.	CloudoraSignIn_CL; ResultType 50126.
Aug 10, 03:12:05	Sign-in	Successful Daniel sign-in from Lagos on Windows 10 / Chrome 125.	CloudoraSignIn_CL; ResultType 0; T1078.
Aug 10, 03:14:30	Sign-in	Daniel mailbox accessed through Outlook Web.	CloudoraSignIn_CL; 102.89.44.17.
Aug 10, 03:18:44	Audit	Attacker registered authenticator app 'Pixel 6'.	CloudoraAudit_CL; T1098.005.
Aug 10, 03:25:02	Sign-in	Daniel Azure Portal session opened.	CloudoraSignIn_CL; 102.89.44.17.

3. Findings

One numbered finding per distinct fact established. Evidence and why it matters are included below.

Finding 1

The CEO account was accessed by an attacker, not by Daniel travelling.
Evidence: Daniel authenticated at 03:12:05 UTC from 102.89.44.17 in Lagos on a Windows 10 / Chrome 125 device never seen on the account before. The success followed failures at 03:09 and 03:10 and was followed by Outlook Web and Azure Portal access. His eight-day baseline was exclusively London, and he signed in normally from London at 08:41.
Why it matters: The failure pattern, 3AM timing, unfamiliar device, and same-day London activity exclude ordinary travel or a benign location anomaly.

Finding 2

Initial access came from a three-night password spray, not phishing.
Evidence: The three Lagos IPs generated 114 failed sign-ins across 26 distinct accounts between 8 and 10 Aug, concentrated between 00:00 and 05:00 UTC. Source counts were 48/23 accounts, 38/20, and 28/18.
Why it matters: Few attempts per account across many accounts is the signature of password spraying (T1110.003).

Finding 3

The attacker established MFA persistence on the CEO account.
Evidence: At 03:18:44 UTC the audit log records an authenticator app on device 'Pixel 6' registered on daniel.reeve from 102.89.44.17 (T1098.005).
Why it matters: The attacker-controlled authentication method could survive a password reset, so credential reset alone was insufficient.

Finding 4

A BEC inbox rule was staged for invoice fraud.
Evidence: At 03:31:09 UTC the attacker created inbox rule 'RSS Subscriptions'; finance@cloudora.io or messages containing 'invoice' were moved to RSS Feeds and marked read (T1564.008).
Why it matters: The rule hides finance conversations and could support invoice fraud. No outbound fraudulent mail was observed in the available logs.

4. Indicators of compromise (IOCs)

Everything another analyst would need to detect or block this attacker: IP addresses, device names, rule names, and where found.

IPv4	102.89.44.17	Aug 08, ~00:00	Lagos, NG. Spray source; CEO access, MFA registration, inbox rule.
IPv4	102.89.44.23	Aug 08, ~00:00	Lagos, NG. Spray source; 28 failures across 18 accounts.
IPv4	102.89.45.101	Aug 08, ~00:00	Lagos, NG. Spray source; Priya compromise.
Device fingerprint	Windows 10 / Chrome 125	Aug 08	Consistent attacker fingerprint on 102.89.x.x activity.
MFA device	Pixel 6	Aug 10, 03:18:44	Attacker-registered authenticator on Daniel; removed.
Inbox rule	RSS Subscriptions	Aug 10, 03:31:09	BEC mail-hiding rule on Daniel; deleted.

5. MITRE ATT&CK; mapping

Map each attacker behaviour observed to a technique. Only map what was actually seen in the logs.

Credential Access	T1110.003	Brute Force: Password Spraying	Finding 2 - 114 failures, 26 accounts, 3 nights, 3 IPs.
Initial Access	T1078	Valid Accounts	Findings 1 and 5 - successful logins with sprayed credentials.
Persistence	T1098.005	Account Manipulation: Device Registration	Finding 3 - attacker authenticator 'Pixel 6'.
Defense Evasion	T1564.008	Hide Artifacts: Email Hiding Rules	Finding 4 - inbox rule 'RSS Subscriptions'.

6. Scope

Accounts confirmed compromised

daniel.reeve@cloudora.io (03:12:05 UTC) and priya.nair@cloudora.io (03:47:18 UTC), both on 10 Aug and both from 102.89.x.x attacker infrastructure, evidenced by successful sign-ins in CloudoraSignIn_CL.

Accounts targeted but not breached

alba.vega, amelia.frost, aria.reid, cole.burke, dina.said, emma.hayes, ethan.wells, freya.lynn, gwen.muir, isla.grant, joel.kerr, jude.ross, kian.patel, leah.stone, lena.voss, liam.doyle, mira.shah, nina.cole, omar.farah, rhys.owen, ruth.dean, ryan.boyd, seth.lane, sofia.marino (all @cloudora.io). These 24 accounts had failed spray attempts only.

Accounts investigated and cleared (false positives)

omar.farah@cloudora.io - Dubai sign-ins assessed as legitimate travel. He remains in the reset list because he was a spray target, but no successful attacker login was observed.

7. Actions taken

Containment first, then eradication, then verification. All times are UTC; actions were executed the morning of 10 Aug.

1	Revoked all active sessions and refresh tokens for daniel.reeve and priya.nair.	Cloudora IT / Security Operations	Live sessions invalidated before reset.
2	Reset credentials for both compromised accounts.	Cloudora IT / Security Operations	New credentials required after session revocation.
3	Removed attacker MFA method 'Pixel 6' from Daniel; reviewed Priya MFA methods and found no attacker method.	Cloudora IT / Security Operations	Attacker MFA path removed / Priya reviewed.
4	Deleted inbox rule 'RSS Subscriptions' from Daniel; audited both mailboxes for further rules.	Cloudora IT / Security Operations	BEC staging removed; mailbox rules reviewed.
5	Blocked 102.89.44.17, 102.89.44.23, and 102.89.45.101 via Conditional Access / named locations.	Cloudora IT / Security Operations	Known attacker infrastructure blocked.
6	Re-ran Step 1 and Step 5 queries; no 102.89.x.x activity after containment; forced re-authentication on both accounts.	Cloudora Security Operations	Containment verified in available sign-in logs.

8. Recommendations

1. Force password resets for the 24 targeted-but-not-breached accounts listed in Section 6 (Finding 2).
2. Require MFA on all accounts and disable legacy authentication protocols that bypass it (Findings 1, 2, 3).
3. Alert on new MFA method registration and new inbox rules for executive accounts (Findings 3 and 4).
4. Deploy a password-spray detection rule based on failures per IP across distinct accounts in a rolling window (Finding 2).

5. Recommendations (continued)

5. Review Conditional Access: block or step-up authentication from countries with no business presence (Findings 1 and 6).
6. Brief the finance team on BEC risk before the enterprise deal closes; verify any payment-detail change by phone on a known number (Finding 4).

9. Lessons learned

What worked in this investigation, what was slow or missing, and what the SOC should do differently. This section is about the response, not the attacker.

- What worked: correlating sign-in and audit events produced the complete attack story; the audit log exposed both the MFA back door and BEC mail-hiding rule.
- What was slow or missing: the password spray was visible on 8 Aug, but the account takeover was only detected after the 10 Aug impossible-travel alert; a basic spray rule would have alerted roughly 51 hours earlier.
- Scope discipline worked: running the attacker-IP success query beyond the CEO identified Priya as a second confirmed victim.
- Baseline comparison worked: Daniel's London-only baseline contrasted with Omar's consistent daytime Dubai activity on his normal device, preventing a false compromise finding.
- The SOC should add scheduled password-spray detection plus alerts for attacker-success-after-spray, new MFA registration, and executive mailbox-rule creation.